Escuela de Innovación Digital

Técnico Superior en Ciberseguridad – D-CS-4-1

Asignatura

Fundamentos de Criptografía

Proyecto Final:

Diseño e Implementación de Infraestructura VPN Cifrada

Estudiantes

Carlos Araúz

4-743-1905

Massiel Pimentel

8-1004-967

Profesor

Santos Douglas

2026

1. Site-to-Site VPN

¿Qué es una Site-to-Site VPN?

Son túneles que permiten la transmisión segura de datos entre dos sitios geográfico distintos.

Características principales:

1.1.1. Infraestructura: El túnel VPN se crea a través de Internet.

1.1.2. Seguridad: Se cifra utilizando una serie de algoritmos de cifrado avanzados.

1.1.3. Propósito: Proporcionar confidencialidad de los datos transmitidos entre los dos sitios.

1.1.4. Autenticación: Puede utilizar claves (Pre-shared keys) o certificados previamente compartidos para la autenticación de los pares (dispositivos en cada extremo).

2. IPSec Site-to-Site VPN

En este modelo, ambos extremos de la conexión son sitios. Estas VPN se clasifican principalmente en función del método utilizado para autenticar los puntos finales del túnel:

2.1.1. Autenticación por PSK (Pre-Shared Key): Se basa en una clave compartida previamente entre ambos extremos.

2.1.2. Autenticación por medio de Certificado: Utiliza certificados digitales para validar la identidad de los sitios. Un ejemplo de gestión de estos es AWS Certificate Manager Private Certificate Authority.

3. Funcionamiento de IPSec

El protocolo IPSec involucra diversas tecnologías de componentes y métodos de cifrado. El proceso se divide generalmente en los siguientes pasos:

3.1.1. Identificación de «tráfico interesante»: El tráfico que cumple con ciertos criterios predefinidos inicia el proceso de negociación de IPSec.

3.1.2. IKE fase 1: El protocolo IKE (Internet Key Exchange) autentica a los pares de IPSec y negocia las AS (Asociaciones Seguras) de IKE. En esta fase se configura un canal seguro que servirá para negociar los parámetros de la siguiente fase.

3.1.3. IKE fase 2 (también conocida como IPSec): IKE negocia los parámetros específicos de las AS de IPSec y configura las asociaciones correspondientes y coincidentes en ambos pares.

3.1.4. Transferencia de datos: Una vez establecido el túnel, los datos se transfieren entre los pares de IPSec aplicando los parámetros de seguridad y las claves acordadas.

Nota: AS = Asociación Segura (Security Association).

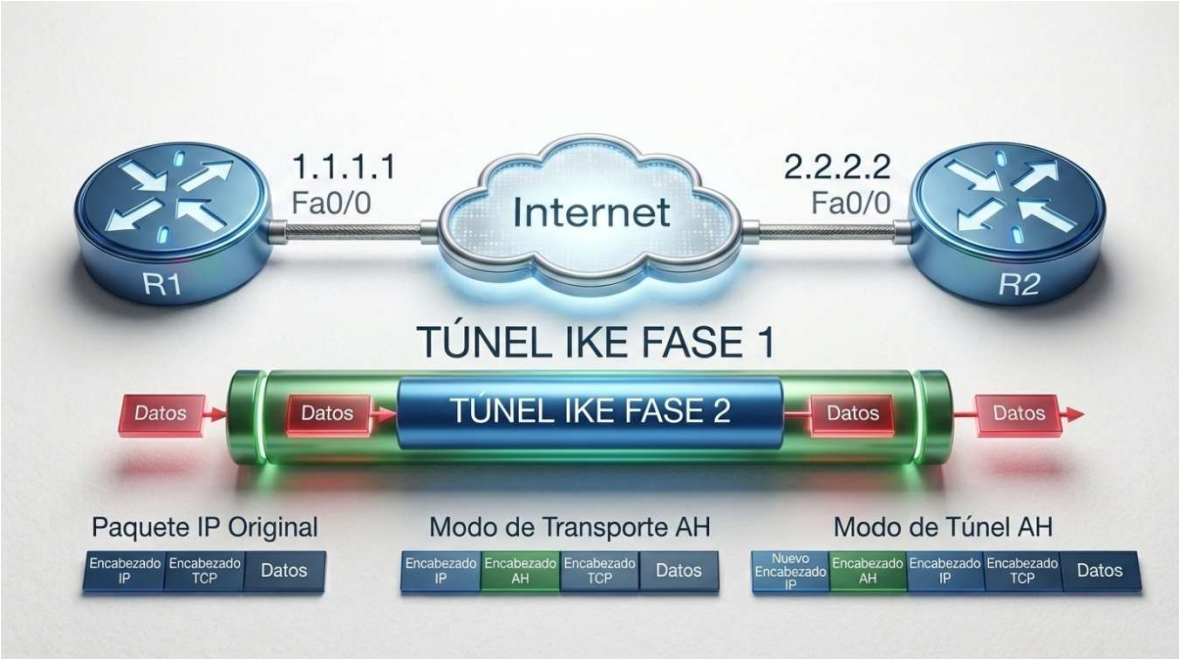

Ilustración 1 *Funcionamiento y fases de IPSEC*

4. Protocolos de IPSEC

Ilustración 2 *Protocolos IPSEC*

AH y/o ESP son los dos protocolos que utilizamos para proteger realmente los datos del usuario. Ambos pueden ser utilizados en modo transporte o en modo túnel. A continuación, exploraremos todas las opciones posibles:

4.1 Protocolo de Cabecera de Autenticación (AH - Authentication Header)

El protocolo AH ofrece autenticación e integridad, pero no proporciona ningún tipo de cifrado. Protege el paquete IP calculando un valor hash sobre casi todos los campos de la cabecera IP.

Los campos que excluye son aquellos que pueden cambiar durante el tránsito (como el TTL y el checksum de la cabecera).

4.1.1. Modo Transporte

El modo transporte es sencillo: simplemente añade una cabecera AH después de la cabecera IP. En una captura de tráfico, se puede observar que la cabecera AH se sitúa entre la cabecera IP y la cabecera del protocolo superior (como ICMP o TCP).

AH utiliza 5 campos principales:

- Siguiente Cabecera (Next Header): Identifica el siguiente protocolo (por ejemplo, ICMP).
- Longitud (Length): Indica la longitud de la cabecera AH.
- SPI (Security Parameters Index): Identificador de 32 bits que permite al receptor saber a qué flujo pertenece este paquete.

- Número de Secuencia (Sequence Number): Ayuda a prevenir ataques de replicación (replay attacks).
- ICV (Integrity Check Value): Es el hash calculado para todo el paquete. El receptor recalcula este hash; si no coincide, el paquete se descarta por falta de integridad.

Ilustración 3 *Modo de transporte AH*

4.1.2. Modo Túnel

En el modo túnel, añadimos una nueva cabecera IP sobre el paquete IP original. Esto es útil cuando se utilizan direcciones IP privadas y se necesita tunelizar el tráfico a través de Internet. Aunque es posible con AH, sigue sin ofrecer cifrado de los datos.

Ilustración 4 *Modo túnel AH*

4.2. Protocolo ESP (ESP - Encapsulating Security Payload)

ESP es la opción más popular de las dos, ya que permite cifrar el tráfico IP, garantizando la confidencialidad además de la integridad y autenticación.

4.2.1. Modo Transporte

En el modo transporte, utilizamos la cabecera IP original e insertamos una cabecera ESP. Se utiliza principalmente para proteger comunicaciones extremo a extremo (host-to-host).

Ilustración 5 *Modo transporte ESS*

4.2.2. Modo Túnel

En el modo túnel para ESP, se añade una nueva cabecera IP, lo cual es fundamental para las VPN sitio a sitio (Site-to-Site). Es similar al modo transporte, pero con la diferencia crítica de que la cabecera IP original también queda cifrada y protegida dentro del nuevo paquete.

Ilustración 6 *Modo Tunel ESP*

4.3. Uso Combinado de AH y ESP

Aunque puede generar confusión, es técnicamente posible utilizar AH y ESP al mismo tiempo para obtener el máximo nivel de seguridad, aplicando las propiedades de ambos protocolos sobre el mismo flujo de datos.

4.3.1. Modo Transporte

Ilustración 7 *Modo Transporte AH+ESP*

4.3.2. Modo Túnel

Ilustración 8 *Modo túnel AH+ESP*

5. Selección del Tipo de VPN y Justificación

5.1. Justificación del Escenario: Se ha elegido una VPN Site-to-Site (S2S) basada en IPsec. Es la solución adecuada porque necesitamos una conexión permanente, transparente y de alto rendimiento entre infraestructuras fijas (Sedes físicas y Cloud). Esto permite que los departamentos (RRHH, Finanzas, Ventas) se comuniquen como si estuvieran en la misma red local sin intervención del usuario.

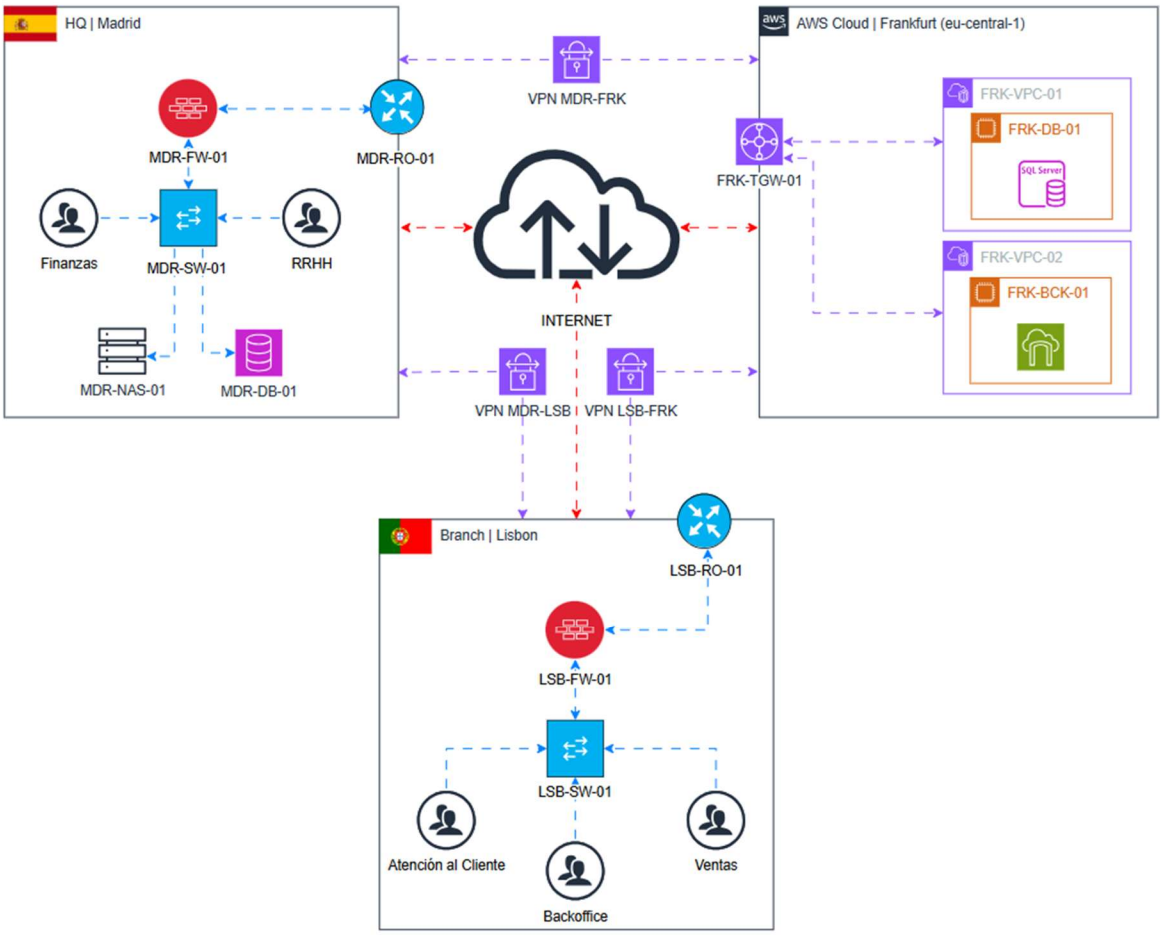

Ilustración 9 *Topología Site to Site Pangea*

5.2. Comparativa y Exclusión:

5.2.1. Remote Access: Este tipo de VPN ha sido excluida ya que está orientada a extender el acceso a usuarios finales para fines como teletrabajo.

5.2.2. SSL VPN: Hemos excluido este modelo de VPN por su mayor alta latencia y porque suele orientarse a acceso a nivel de aplicación en lugar de interconexión total de red a nivel de capa 3.

6. **Algoritmos de Cifrado y Protocolos**

6.1. Cifrado en tránsito: Se utiliza AES-256-GCM (Galois/Counter Mode).

6.2. Longitud de clave: 256 bits (Seguridad de grado militar).

6.3. Modo: GCM se elige sobre CBC porque es un cifrado AEAD (Authenticated Encryption with Associated Data), lo que permite cifrado y autenticación de integridad en un solo paso, siendo más rápido y resistente a ataques de relleno (padding oracle).

6.4. Rechazo de opciones débiles: DES y 3DES se rechazan por su vulnerabilidad a colisiones y ataques de fuerza bruta. RC4 se rechaza por sesgos estadísticos en su flujo de claves.

6.4.1. Autenticación e Integridad: Se implementa HMAC-SHA-256. Proporciona una "huella digital" única para cada paquete, garantizando que los datos no han sido alterados.

6.5. Intercambio de claves: Se utiliza ECDH (Elliptic Curve Diffie-Hellman) con el Grupo 19 (Curva P-256). Ofrece una seguridad equivalente a RSA de 3072 bits pero con mucha menor carga computacional.

6.6. Protocolo de túneles: IPsec con IKEv2.

Ventaja: IKEv2 soporta MOBIKE (resiliencia ante cambios de IP), tiene un intercambio de mensajes más reducido y soporta de forma nativa la detección de túneles "muertos" (Dead Peer Detection).

7. **Infraestructura**

7.1. Topología: Configuración Full Mesh entre MDR-RO-01, LSB-RO-01 y AWS Transit Gateway (TGW). El TGW actúa como concentrador en la nube para las VPCs de base de datos y backup.

7.2. Capacidad de Procesamiento: El hardware recomendado (o instancias tipo c5.large en AWS) debe soportar instrucciones AES-NI para acelerar el cifrado por hardware. Con AES-256-GCM, el consumo esperado es de 1.25 Gbps por túnel sin degradación significativa de latencia.

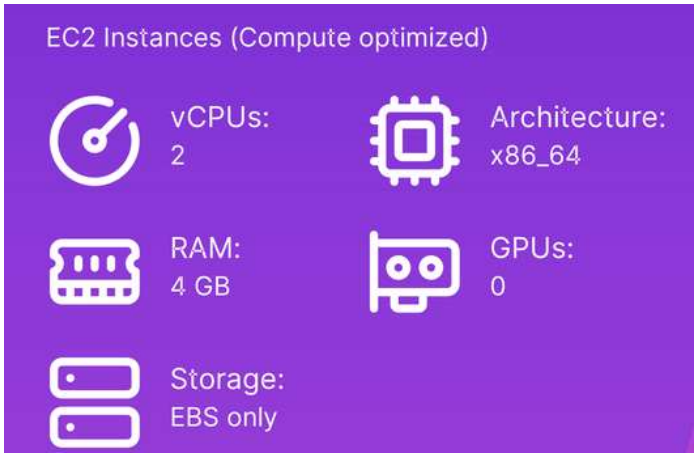

Ilustración 10 *Recursos de instanciade AWS EC2 c5.large*

7.3. Alta Disponibilidad: Se han diseñado túneles redundantes (Dual-Tunnel) hacia AWS TGW. En caso de caída de un ISP, el protocolo BGP (Border Gateway Protocol) realiza el failover automático en menos de 30 segundos.

8. Seguridad

8.1. Autenticación Multifactor (MFA): Al ser una conexión Site-to-Site (dispositivo a dispositivo), el concepto de MFA de usuario (OTP/SMS) no aplica. La seguridad reside en la autenticación de dispositivos mediante Certificados Digitales.

8.2. Certificados Digitales vs PSK: Se opta por Certificados Digitales (PKI) con RSA de 4096 bits.

Argumento: Las PSK son vulnerables a ataques de diccionario y difíciles de rotar en entornos de varias sedes. La PKI permite el ciclo de vida (emisión/revocación) y garantiza el no repudio. Se incluye validación por OCSP para verificar la validez en tiempo real.

8.3. Políticas de Acceso: Se aplica RBAC y segmentación. Por ejemplo, el segmento "Ventas" en Lisboa solo tiene acceso a la "FRK-DB-01" en AWS por el puerto 1433 (SQL), limitando el movimiento lateral.

8.4. Monitoreo: Uso de SNMP v3 y CloudWatch logs. Métricas clave: túneles "Up/Down", fallos de negociación IKE y geolocalización de intentos de conexión no autorizados.

9. Consideraciones Operativas

9.1. Documentación: Se utilizarán Baselines de Seguridad basados en los benchmarks de la CIS (Center for Internet Security).

9.2. Respaldo y Recuperación: Backups cifrados de las configuraciones de los Firewalls. La Clave Raíz de la CA (Autoridad de Certificación) se almacena en un dispositivo offline (Air-gapped) o un HSM en la nube.

9.3. Pruebas de Penetración: Frecuencia Semestral. Alcance: Pruebas de ataques de negociación (downgrade), ataques de repetición (replay) y escaneo de vulnerabilidades en los servicios IKE expuestos.

9.4. Actualizaciones: Política de parcheo "Critical-First" (parcheo en máximo 48h para vulnerabilidades críticas en el concentrador VPN).

10. Cumplimiento Normativo

10.1. Identificación de la Normativa:

- GDPR: Aplicable obligatoriamente ya que las sedes están en España, Portugal y Alemania. Garantiza el derecho a la privacidad de los datos de empleados.

10.2. Retención de Logs: Se establece una retención de 13 meses para logs de seguridad (alineado con mejores prácticas de auditoría).

10.3. Estándares del Sector: Cumplimiento con el ENS (Esquema Nacional de Seguridad) de España (Nivel Medio/Alto) y guías del NIST SP 800-77 para VPNs IPsec.